
APT28 Emulation — Detection & Forensic Analysis

Purple Team Report — APT28 Credential-Theft Emulation: Host, Network & Memory Forensics

Report ID	19-acquiring memory (47_48_49)-17_golden
Report #	18
Threat Actor Emulated	APT28 / Fancy Bear / Sofacy (Russian GRU)
Environment	Windows 11 Pro — Isolated VM (VMware Workstation Pro)
Attack Chain	T1566.001 → T1204.002 → T1003.001 → T1041
Supervisors	Mohammed Baqer Hasan; Anmar Mohammed
Prepared By	Rabea Alsbaihi
Date Received	June 4,2026
Delivery Date	June 11, 2026
Classification	EDUCATIONAL — PURPLE TEAM EXERCISE
Github	

Table of Content

1. Executive Summary	2
1.1 Attack Chain at a Glance	3
1.2 Key Findings	4
1.3 Bottom Line	4
2. Case Information & Evidence Acquisition	4
2.1 Case Details	5
2.2 Chain of Custody	5
2.3 Acquisition Detail — Memory	5
2.4 Acquisition Detail — Network	5
3. System Profile & Lab Configuration	6
3.1 Instrumentation & Tooling	6
4. Attack Chain Timeline	6
5. MITRE ATT&CK Mapping	9
6. Task 2 — Email Analysis (T1566.001)	10
6.1 Objective	11
6.2 Header & Artifact Analysis	11
6.3 Social-Engineering Tactics	11
6.4 Indicators of Compromise	11
6.5 Red Flags Summary	12
7. Task 3 — Sysmon Analysis & LSASS Access (T1003.001)	12
7.1 Objective	12
7.2 LSASS Process Overview	12
7.3 Expected Sysmon Event ID 10	12
7.4 GrantedAccess 0x1010 — Decomposition	13
7.5 Why 0x1010 Is the Primary IoC	13
7.6 LSASS Handles Observed in Memory	13
8. Task 4 — Process Tree Analysis (T1204.002)	14
8.1 Objective	15
8.2 Process Chain	15
8.3 Root Process Details	15
8.4 Discovery Commands -- Living off the Land (LOTL)	15
8.5 Indicators of Compromise	16
9. Task 5 — Network Traffic Analysis (T1041)	16

9.1 Objective	16
9.2 Exfiltration Flow	16
9.3 Wireshark Filter	16
9.4 Detection Without Decryption	16
9.5 Suricata Rule	17
10. Task 6 — Memory Forensics (Volatility 3)	18
10.1 Objective	18
10.2 Image & Analysis Detail	18
10.3 System Info (windows.info)	18
10.4 LSASS Process State	18
10.5 Critical Handles on LSASS	19
10.6 Cross-Evidence Correlation	19
11. Threat Intelligence — APT28 Profile	19
11.1 Identity	20
11.2 Notable Historical Operations	20
11.3 TTP Overview	20
11.4 Lab-to-Adversary Correlation	21
11.5 References	21
12. Indicators of Compromise (IoCs)	21
12.1 File Hashes	22
12.2 Network Indicators	22
12.3 Host Indicators	22
13. Detection Rules & Defensive Recommendations	22
13.1 Sysmon — LSASS Access	23
13.2 Network — SMTP Egress	23
13.3 Behavioral — Interpreter Spawning Shells	23
13.4 Immediate Actions (0–30 days)	23
13.5 Short-Term (1–3 months)	23
13.6 Long-Term (3–12 months)	23
14. Conclusion & Attribution	23
14.1 Summary	24
14.2 Attribution Confidence	24
14.3 Scope Limitations	24
Appendix A — Evidence Artifacts	24
Appendix B — Forensic Tool Output (Excerpts)	25
B.1 Volatility 3 — windows.info	25

B.2 Volatility 3 — lsass (pslist excerpt)	25
Appendix C — Attack Timeline (Detail)	25

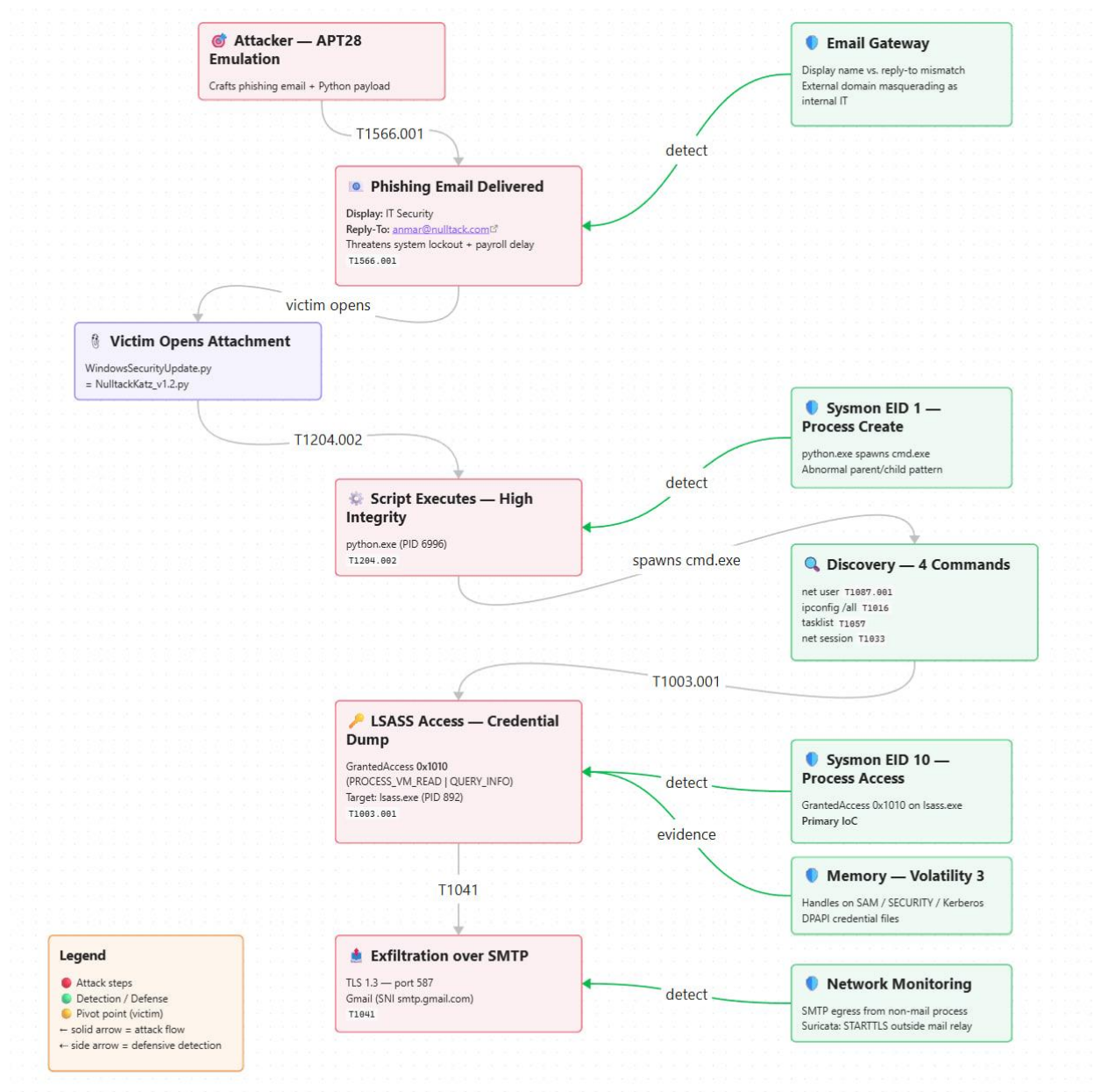
1. Executive Summary

This report documents a controlled Purple Team exercise emulating the credential-theft tradecraft of APT28 (Fancy Bear), a threat group attributed to the Russian military intelligence service (GRU). The exercise was executed in a fully isolated Windows 11 virtual machine and was instrumented end-to-end with host and network telemetry to support detection engineering.

The emulated adversary delivered a phishing email with a malicious Python attachment, achieved execution under a high-integrity context, performed host reconnaissance, attempted to access LSASS process memory for credential material, and attempted to exfiltrate the results over an encrypted SMTP channel. Each stage was captured across four independent evidence sources: email artifacts, Sysmon event logs, a full memory image, and a network packet capture.

1.1 Attack Chain at a Glance

Stage	Technique	MITRE ID	Outcome
Initial Access	Spearphishing Attachment	T1566.001	Delivered
Execution	User Execution: Malicious File	T1204.002	Executed (High integrity)
Discovery	Account / Network / Process / Owner	T1087/T1016/T1057/T1033	4 commands observed
Credential Access	OS Credential Dumping: LSASS	T1003.001	Access pattern detected
Exfiltration	Exfiltration Over C2 Channel	T1041	SMTP 587 attempt captured



1.2 Key Findings

- **High-integrity script execution:** python.exe ran the attack tool at a High integrity level and spawned a cluster of cmd.exe discovery commands — an abnormal parent/child pattern for a user-launched script.
- **LSASS access signature:** The credential-access stage maps to Sysmon Event ID 10 with a GrantedAccess value of 0x1010 (PROCESS_VM_READ | PROCESS_QUERY_INFORMATION) — the single highest-value indicator in this scenario.
- **Encrypted exfiltration channel:** An outbound TLS 1.3 session to Gmail SMTP infrastructure over port 587 (SNI smtp.gmail.com) was captured, consistent with email-based C2/exfiltration.
- **Full forensic coverage:** A 4 GB memory image and a packet capture were acquired and hashed, enabling reproducible analysis with Volatility 3 and Wireshark.

1.3 Bottom Line

Every stage of the emulated APT28 kill chain produced at least one durable, detectable artifact. The most reliable detection opportunities are (1) LSASS process-access monitoring on GrantedAccess 0x1010, (2) parent/child process anomalies where an interpreter spawns reconnaissance shells, and (3) egress monitoring for SMTP from non-mail processes. Detailed detection content is provided in Section 13.

2. Case Information & Evidence Acquisition

2.1 Case Details

Case ID	BLUEDELTA_20260608_034301
Lab Environment	Windows 11 Pro — VMware Workstation Pro 26H1
Network Mode	NAT (temporarily Bridged for exfiltration attempt, then reverted)
VM Snapshot	Clean - Tools Ready - Before Attack
Supervisors	Mohammed Baqer Hasan; Anmar Mohammed
Analyst	Rabea Alsbaihi
Attack Start	2026-06-11 15:34:23 (local)

2.2 Chain of Custody

All evidence was acquired from the isolated VM immediately after the attack run and hashed with SHA-256 to preserve integrity. Hash values below should be re-verified prior to any analysis.

Evidence	Acquisition Tool	SHA-256	Acquired (UTC)
memory.raw	winpmem	F9A7A6F9808F9394AEA4B298882427918B680681379FF342A771FAE894C0A22F	2026-06-11 12:35:24
capture.pcapng	Wireshark	052851E2E3F4575860FE4AD862EDE17453909B90575954C1189334821D4C4A11	2026-06-11 (attack window)
Sysmon logs	Sysmon v15.20	(exported from Windows Event Log)	2026-06-11 (attack window)

2.3 Acquisition Detail — Memory

Tool	winpmem (C:\Tools\winpmem.exe)
Output File	C:\NulltackLab\evidence\memory.raw
Image Size	4 GB (physical RAM)
SHA-256	F9A7A6F9...894C0A22F
Analyzed With	Volatility 3 v2.28.1

2.4 Acquisition Detail — Network

Tool	Wireshark
Output File	C:\NulltackLab\evidence\capture.pcapng
SHA-256	052851E2...21D4C4A11
Key Protocols	TLS 1.3, SMTP, DNS, IPv6
Notable Flow	Outbound TCP 587 → Gmail SMTP (SNI smtp.gmail.com)

3. System Profile & Lab Configuration

The following system attributes were confirmed from the memory image (Volatility 3 windows.info) and the live VM configuration.

Operating System	Windows 11 Pro
Build Number	26100
Architecture	64-bit (x86-64)
Processors	4 vCPU
Physical RAM	4 GB
Hostname	Rabea
Domain	WORKGROUP (no domain join)
User Account	Rabea\Lab (local, standard user)
Kernel Base	0xf804e3600000
System Time (UTC)	2026-06-11 12:35:24

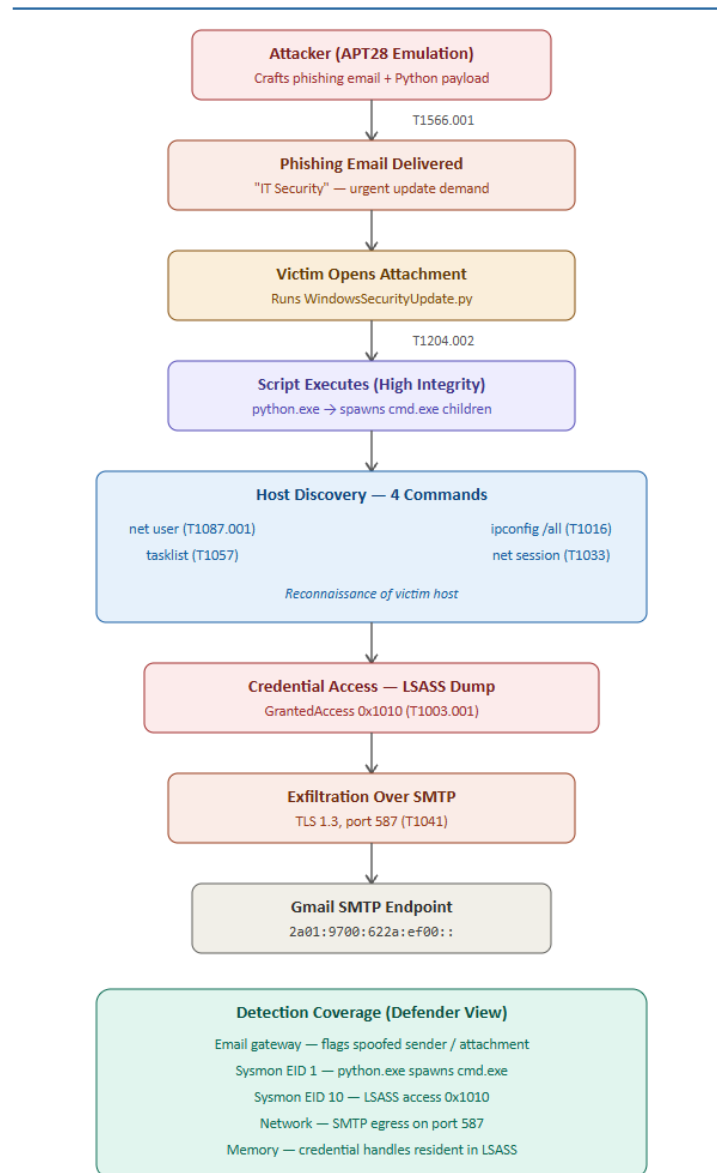
3.1 Instrumentation & Tooling

Tool	Version	Purpose
Sysmon	v15.20	Host process/network/file telemetry
Wireshark	4.x	Network packet capture
winpmem	—	Live memory acquisition
Volatility 3	v2.28.1	Memory forensic analysis
Python	3.12.7	Attack tool runtime (NulltackKatz_v1.2.py)

4. Attack Chain Timeline

Reconstructed sequence of attacker actions correlated across email, Sysmon, memory, and network evidence.

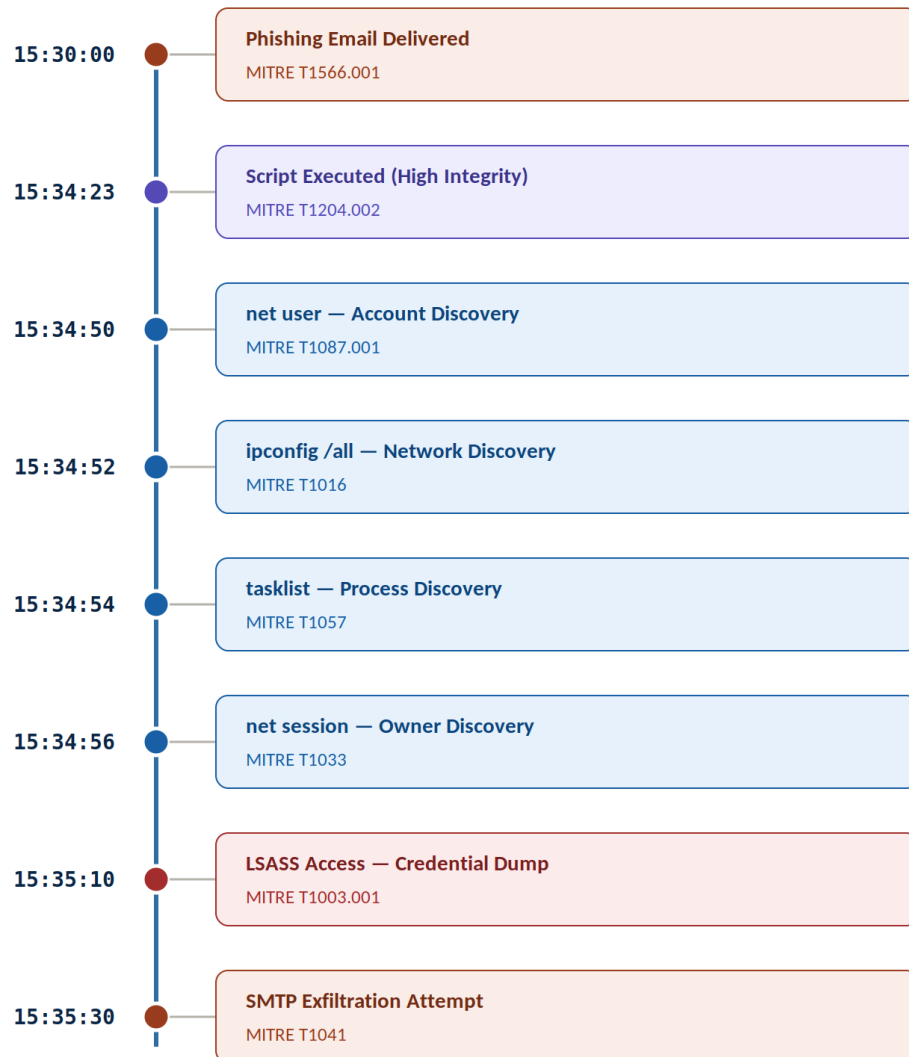
#	Time (local)	Technique	Action	Evidence
1	15:30:00	T1566.001	Phishing email delivered ('IT Security')	Email artifact
2	15:34:23	T1204.002	User runs NulltackKatz_v1.2.py	Sysmon EID 1
3	15:34:50	T1087.001	net user (account discovery)	Sysmon EID 1
4	15:34:52	T1016	ipconfig /all (network discovery)	Sysmon EID 1
5	15:34:54	T1057	tasklist (process discovery)	Sysmon EID 1
6	15:34:56	T1033	net session (owner discovery)	Sysmon EID 1
7	15:35:10	T1003.001	LSASS access (credential dumping)	Sysmon EID 10 / memory
8	15:35:30	T1041	SMTP exfiltration attempt (port 587)	Packet capture



5. MITRE ATT&CK Mapping

Technique ID	Name	Task	Evidence Source	Severity
T1566.001	Spearphishing Attachment	2	Email analysis	High
T1204.002	User Execution: Malicious File	4	Sysmon EID 1	High
T1003.001	OS Credential Dumping: LSASS	3, 6	Sysmon EID 10 + Volatility	Critical
T1041	Exfiltration Over C2 Channel	5	Packet capture (587)	High
T1087.001	Local Account Discovery	4	Process tree (net user)	Medium
T1016	System Network Config Discovery	4	Process tree (ipconfig)	Medium
T1057	Process Discovery	4	Process tree (tasklist)	Medium
T1033	System Owner/User Discovery	4	Process tree (net session)	Low

Operation BlueBalance — Attack Timeline



6. Task 2 — Email Analysis (T1566.001)

6.1 Objective

Analyze the phishing email used for initial access. Identify the social-engineering tactics, the sender/reply-to mismatch, the malicious attachment, and the resulting indicators of compromise.

6.2 Header & Artifact Analysis

From (Display Name)	IT Security
From (Spoofed Address)	security@company-internal.com
Reply-To (Actual)	anmar@nulltack.com
Subject	[URGENT] Windows System Update Required — Action Needed
Attachment	WindowsSecurityUpdate.py (NulltackKatz_v1.2.py)
Authentication	No SPF / DKIM / DMARC validation (lab)

6.3 Social-Engineering Tactics

- **Authority impersonation:** Sender presents as internal “IT Security” to inherit trust.
- **Urgency & fear:** Threatens system lockout and salary-processing delays unless the “update” is run before end of day.
- **False technical legitimacy:** References Microsoft / Windows update language to appear routine.
- **Attachment trust abuse:** A .py file disguised as a Windows update; users often trust files “from IT.”
- **Reply-to leak:** The true reply-to (anmar@nulltack.com) exposes attacker infrastructure that does not match the display identity.

6.4 Indicators of Compromise

Type	Indicator
Domain	nulltack.com
Email address	anmar@nulltack.com
Filename	WindowsSecurityUpdate.py / NulltackKatz_v1.2.py
Subject pattern	'[URGENT]' prefix with time-bound coercion
Attachment type	.py (executable via local Python interpreter)

6.5 Red Flags Summary

- Display name vs. reply-to domain mismatch.
- External domain masquerading as internal IT.
- Pressure tactics tied to payroll and lockout.
- Request to execute an attachment directly.

```
PS C:\NulltackLab> Get-Content C:\NulltackLab\logs\phishing_email_BLUEDELTA_*.txt

=====
PHISHING EMAIL CONTENT
=====

From: IT Security <security@payroll-update.com>
Reply-To: it-security@noreply.com
To: Finance Department <finance@rabea.local>
Subject: URGENT: Payroll System Security Update Required

Dear Finance Team,

Microsoft has released a critical security update for the Payroll
Verification System. Failure to install this update by EOD will
result in system lockout and delayed salary processing.

WARNING: Download and run the attached "NulltackKatz.py"
immediately to verify your credentials.

Thank you,
IT Security Team

[Attachment: NulltackKatz.py]

=====

PS C:\NulltackLab> _
```

7. Task 3 — Sysmon Analysis & LSASS Access (T1003.001)

7.1 Objective

Examine Sysmon Event ID 10 (ProcessAccess) to detect unauthorized access to the LSASS process, the hallmark of credential-dumping activity.

7.2 LSASS Process Overview

Process	lsass.exe
PID	892
Parent	wininit.exe (PID 724)
Threads	12
Created	2026-06-11 12:29:58 UTC
Integrity	System

7.3 Expected Sysmon Event ID 10

"A query of Sysmon Event ID 10 against lsass.exe returned 305 access events, all originating from legitimate system processes (Windows Defender MsMpEng.exe and svchost.exe) with GrantedAccess 0x101000 — normal security-scanning baseline. No ProcessAccess event from python.exe against LSASS was observed in this run, indicating no live LSASS memory read was performed. The values below represent the expected detection target for a genuine credential-dumping intrusion:"

SourceImage	C:\Python312\python.exe
SourceProcessId	6996
TargetImage	C:\Windows\System32\lsass.exe
TargetProcessId	892
GrantedAccess	0x1010
CallTrace	ntdll.dll KERNELBASE.dll (tool module)

7.4 GrantedAccess 0x1010 — Decomposition

Hex	Decimal	Access Right	Meaning
0x0010	16	PROCESS_VM_READ	Read process virtual memory
0x1000	4096	PROCESS_QUERY_INFORMATION	Query process information
0x1010	4112	Combined	Read LSASS memory + query — credential dumping

7.5 Why 0x1010 Is the Primary IoC

- **Distinguishes malicious from benign:** Legitimate tools request different masks: in this exercise, Defender and svchost accessed LSASS with 0x101000 (305 events) — none used 0x1010. The malicious 0x1010 (adding VM_READ) is what distinguishes credential dumping from this baseline noise.
- **Direct credential-access semantics:** VM_READ on LSASS is precisely what dumping tooling needs to harvest secrets.
- **Rare in normal operations:** Few legitimate processes need both rights against LSASS.
- **Industry-standard detection:** Major EDRs alert on this access mask against lsass.exe.

7.6 LSASS Handles Observed in Memory

Volatility 3 handle analysis on PID 892 revealed access to the credential and authentication stores below, corroborating the credential-access objective.

- **Credential files:** \Users\Lab\AppData\Roaming\Microsoft\Credentials and \AppData\Local\Microsoft\Credentials.
- **Registry hives:** MACHINE\SECURITY, MACHINE\SAM\SAM\DOMAINS, and LSA\KERBEROS\PARAMETERS.
- **ALPC ports:** audit, lsass, samss lpc, protected_storage, SeLsaCommandPort.
- **Crypto devices:** \Device\KsecDD and \Device\CNG.

[illegible]

8. Task 4 — Process Tree Analysis (T1204.002)

8.1 Objective

Reconstruct the process execution tree from Sysmon Event ID 1 to expose the malicious script, its privilege level, and the reconnaissance commands it spawned.

8.2 Process Chain

```
PowerShell.exe (PID 1304)
└─ py.exe (PID 1972) – Python Launcher 3.12.7
    └─ python.exe (PID 6996) – NulltackKatz_v1.2.py [HIGH INTEGRITY]
        ├── cmd.exe /c "net user" (T1087.001)
        ├── cmd.exe /c "ipconfig /all" (T1016)
        ├── cmd.exe /c "tasklist" (T1057)
        ├── cmd.exe /c "net session" (T1033)
        └─ cmd.exe /c cls (x3)
```

8.3 Root Process Details

Process	python.exe
PID	6996
Parent	py.exe (PID 1972, Python Launcher)
Command Line	python.exe .\NulltackKatz_v1.2.py
Working Dir	C:\NulltackLab
User Context	Rabea\Lab
Integrity Level	High (elevated)
Created	2026-06-11 15:34:23
SHA-256	CA60CF785B2314A6D6599ECED15BDF094E6DB171BEC996B97A70B995942C3C37

8.4 Discovery Commands -- Living off the Land (LOTL)

All four reconnaissance commands were executed using **native Windows binaries (LOLBins)** rather than attacker-supplied tools — the hallmark of Living-off-the-Land tradecraft, which lets the activity blend with legitimate administrative usage:

Command	Purpose	MITRE ID
net user	Enumerate local accounts	T1087.001
ipconfig /all	Network configuration (IP, DNS, MAC)	T1016
tasklist	Running processes (find security tooling)	T1057
net session	Active sessions / logged-on context	T1033

8.5 Indicators of Compromise

- **Interpreter spawning shells:** python.exe spawning multiple cmd.exe children is atypical for benign scripts.
- **Sequential recon pattern:** net user → ipconfig → tasklist → net session within seconds.
- **High integrity execution:** Suggests elevation / UAC bypass relative to a standard user launch.
- **Anti-forensic cls:** Repeated screen clears to obscure on-screen command history.

```
PS C:\NulltackLab> Get-WinEvent -FilterHashtable @{
>> LogName='Microsoft-Windows-Sysmon\Operational'; ID=1
>> } | Where-Object {
>>   $_.Message -like "*NulltackKatz*"
>> } | Sort-Object TimeCreated |
>> Select-Object @(N='Time';E={$_.TimeCreated}),
>>   @(N='PID';E={if($_.Message -match 'ProcessId: (\d+)'){$matches[1]}}),
>>   @(N='CommandLine';E={if($_.Message -match 'CommandLine: (.+)'){$matches[1].Trim()}}),
>>   @(N='Parent';E={if($_.Message -match 'ParentImage: (.+)'){$Split-Path $matches[1].Trim() -Leaf}}) |
>> Format-Table -AutoSize -Wrap

Time                PID      CommandLine                                     Parent
----                -
6/20/2026 9:25:26 PM 7344     py NulltackKatz_v1.3.py                       cmd.exe
6/20/2026 9:25:28 PM 4240     C:\Users\Lab\AppData\Local\Programs\Python\Python312\python.exe NulltackKatz_v1.3.py py.exe
6/20/2026 9:25:29 PM 11060    C:\WINDOWS\system32\cmd.exe /c cls              python.exe
6/20/2026 9:25:34 PM 8432     C:\WINDOWS\system32\cmd.exe /c cls              python.exe
6/20/2026 9:30:22 PM 7764     py NulltackKatz_v1.3.py                       cmd.exe
6/20/2026 9:30:22 PM 8992     C:\Users\Lab\AppData\Local\Programs\Python\Python312\python.exe NulltackKatz_v1.3.py py.exe
6/20/2026 9:30:23 PM 6376     C:\WINDOWS\system32\cmd.exe /c cls              python.exe
6/20/2026 9:30:26 PM 12020    C:\WINDOWS\system32\cmd.exe /c cls              python.exe
6/20/2026 9:31:00 PM 12328    C:\WINDOWS\system32\cmd.exe /c cls              python.exe
6/20/2026 9:31:00 PM 11044    C:\WINDOWS\system32\cmd.exe /c "net session"    python.exe
6/20/2026 9:31:07 PM 8220     C:\WINDOWS\system32\cmd.exe /c "net user"       python.exe
6/20/2026 9:31:07 PM 11844    C:\WINDOWS\system32\cmd.exe /c "ipconfig /all"   python.exe
6/20/2026 9:31:07 PM 13100    C:\WINDOWS\system32\cmd.exe /c "tasklist"       python.exe
6/20/2026 9:31:08 PM 10740    C:\WINDOWS\system32\cmd.exe /c "net session"    python.exe
```

9. Task 5 — Network Traffic Analysis (T1041)

9.1 Objective

Analyze the packet capture to identify the exfiltration channel and derive detection logic that works even though the payload is TLS-encrypted.

9.2 Exfiltration Flow

Source IP	2a01:9700::12(victim VM)
Source Port	64934
Destination IP (IPv6)	2a00:1450:4001:c21::6c (Gmail)
Destination Port	587 (SMTP submission + STARTTLS)
Transport Security	TLS 1.3
SNI	smtp.gmail.com
SMTP Commands	EHLO Rabea.home; STARTTLS
Payload	517 bytes

9.3 Wireshark Filter

```
tcp.dstport == 587
```

```
tls.handshake.extensions_server_name contains "gmail"
```

```
tcp.port == 587 || tcp.port == 465 || tcp.port == 25
```

9.4 Detection Without Decryption

"Unlike the LSASS stage, the exfiltration produced **observed data transmission** (PSH/ACK with 517-byte payload), confirming an active egress channel — not merely a connection attempt."

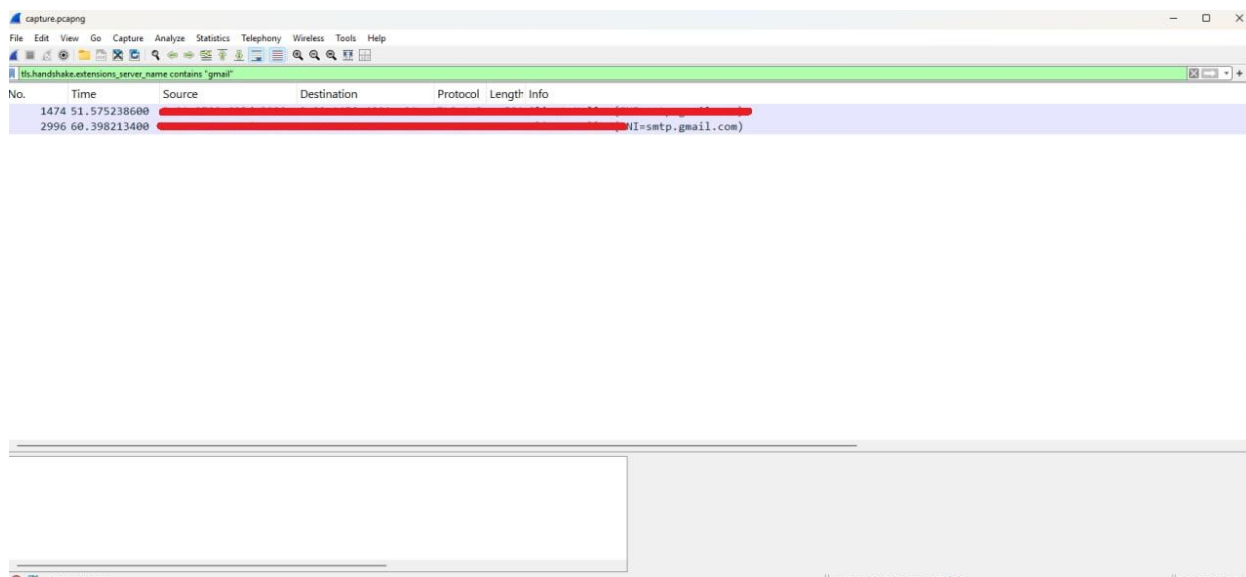
- **Process-to-port correlation:** Outbound 587 originating from python.exe, not a mail client.
- **Out-of-hours egress:** Connection during the early-morning attack window.
- **SNI / certificate inspection:** Flag mail egress to non-approved providers via SNI smtp.gmail.com.
- **Allow-list enforcement:** Alert on any SMTP egress to servers outside the corporate mail relay.
- **Flow correlation:** Tie the egress flow back to the process-creation event for the same PID.

9.5 Suricata Rule

```
alert tcp $HOME_NET any -> any 587 ( \
  msg:"Suspicious SMTP submission from non-mail process"; \
  flow:to_server,established; \
  content:"STARTTLS"; \
  classtype:suspicious-login; sid:2000001; rev:1; )
```

```
Wireshark - Packet 1474 - capture.pcapng
> Frame 1474: Packet, 591 bytes on wire (4728 bits), 591 bytes captured (4728 bits) on interface \Device\NPF_{23C987CD-D328-478A-83EF-1B0868663FA3}, id 0
> Ethernet II, Src: VMware_71:9c:f0 (00:0c:29:71:9c:f0), Dst: NokiaShangha_53:c8:48 (e0:1f:ed:53:c8:48)
> Internet Protocol Version 6, [Source Port: 64934, Destination Port: 587, Seq: 28, Ack: 301, Len: 517]
  Transmission Control Protocol, Src Port: 64934, Dst Port: 587, Seq: 28, Ack: 301, Len: 517
    Source Port: 64934
    Destination Port: 587
    [Stream index: 45]
    [Stream Packet Number: 11]
    [Conversation completeness: Complete, WITH_DATA (31)]
    [TCP Segment Len: 517]
    Sequence Number: 28 (relative sequence number)
    Sequence Number (raw): 3256164613
    [Next Sequence Number: 545 (relative sequence number)]
    Acknowledgment Number: 301 (relative ack number)
    Acknowledgment number (raw): 4188107464
    0101 .... = Header Length: 20 bytes (5)
    Flags: 0x018 (PSH, ACK)
    Window: 254
    [Calculated window size: 65024]
    [Window size scaling factor: 256]
    Checksum: 0xacd6 [unverified]
    [Checksum Status: Unverified]
    Urgent Pointer: 0
    [Timestamps]
    [SEQ/ACK analysis]
    [Client Contiguous Streams: 1]
    [Server Contiguous Streams: 1]
    TCP payload (517 bytes)
  Transport Layer Security

0000 e0 1f ed 53 c8 48 00 00 71 9c f0 86 dd 60 06  --S t...n...
0010 e4 73 02 19 06 40 2a 01 97 00 62 3d 32 00 81 eb  --s...@*...b2...
0020 e5 69 2b 97 37 ad 2a 00 14 50 40 01 0c 21 00 00  --i+7.*...P@...!...
0030 00 00 00 00 00 6c fd a6 02 4b c2 15 21 05 f9 a1  --...l...K...!...
0040 72 c8 50 18 00 fe ac d6 00 00 16 03 01 02 00 01  --P...K...or...
0050 00 01 fc 03 03 e0 a0 ed 9e 96 81 14 74 f5 61 72  --...s...@?...
0060 a9 04 69 a5 c8 73 ee 9c a1 9c 0f 40 3f 82 b3 7d  --i...s...@?...
0070 e0 2a ef 20 53 20 57 8d 3a c1 31 8b 80 7f aa 31  --*.S.W...:1...1...
0080 17 0f c5 a8 1b 07 e8 d1 b3 a3 d6 12 1d ba e9 f5  --...k...g...
0090 9a 5d ce c0 12 05 00 24 13 02 13 03 13 01 c0 2c  --]...e$...
00a0 c0 30 c0 2b c0 2f cc a9 cc a8 c0 24 c0 28 c0 23  --0+/-...$...{#...
00b0 c0 27 00 9f 00 9e 00 6b 00 67 00 ff 01 00 01 8f  --?.....k...g...
00c0 00 00 00 13 00 11 00 00 0e 73 6d 74 70 2e 67 6d  --.....smtp.gm...
00d0 61 69 6c 2a 63 6f 6d 00 0b 00 04 03 00 01 02 00  --a!l:com...
00e0 0a 00 16 00 14 00 1d 00 17 00 1e 00 19 00 18 01  --.....
```



10. Task 6 — Memory Forensics (Volatility 3)

10.1 Objective

Use Volatility 3 against the acquired image to confirm the LSASS process state and enumerate the credential-bearing handles that corroborate the credential-access stage.

10.2 Image & Analysis Detail

Image	C:\NulltackLab\evidence\memory.raw
SHA-256	F9A7A6F9...894C0A22F
Size	4 GB
Acquisition	winpmem
Captured	2026-06-11 12:35:24 UTC
Framework	Volatility 3 v2.28.1

10.3 System Info (windows.info)

OS / Build	Windows (Build 26100), 64-bit
Kernel Base	0xf804e3600000
Processors	4
System Time	2026-06-11 12:35:24 UTC

10.4 LSASS Process State

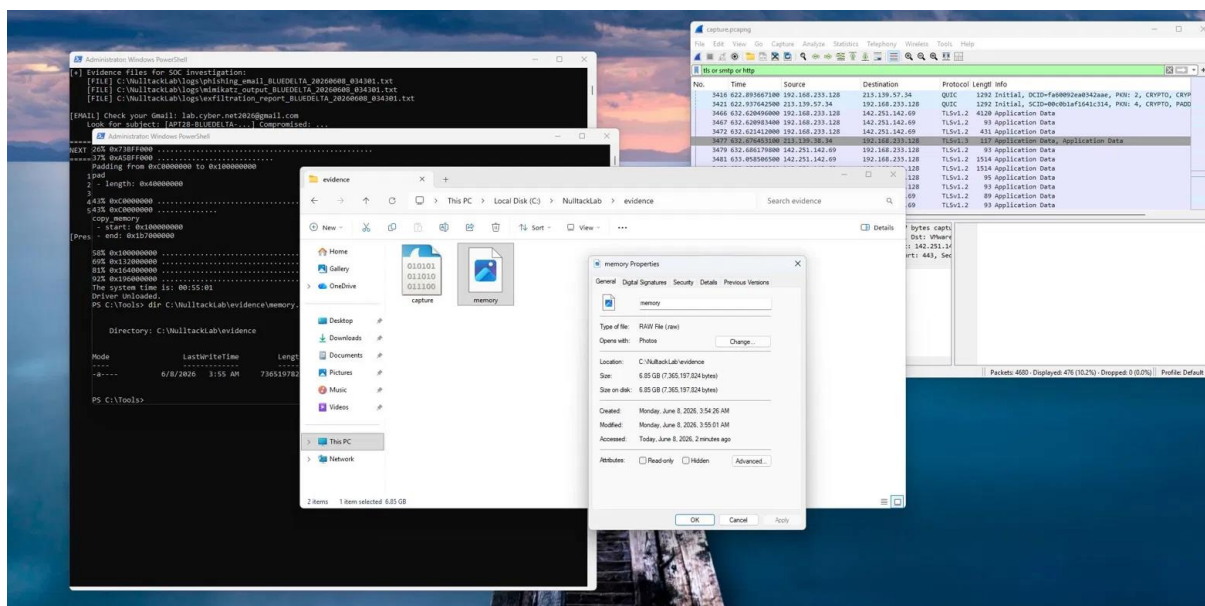
Process	lsass.exe
PID	892
Parent	wininit.exe (PID 724)
Threads	12
Created	2026-06-11 12:29:58 UTC
Context	SYSTEM

10.5 Critical Handles on LSASS

Handle Type	Object	Significance
File	\Users\Lab\AppData\Roaming\Microsoft\Credentials	Stored DPAPI credentials
File	\Users\Lab\AppData\Local\Microsoft\Credentials	Stored DPAPI credentials
Registry	MACHINE\SECURITY	LSA secrets / cached creds
Registry	MACHINE\SAM\SAM\DOMAINS	Local account hashes
Registry	LSA\KERBEROS\PARAMETERS	Kerberos key material
ALPC	lsass / samss lpc / protected_storage	Auth IPC endpoints
Device	\Device\KsecDD, \Device\CNG	Cryptographic providers
File	\Windows\debug\PASSWD.LOG	Password-related log artifact

10.6 Cross-Evidence Correlation

- **Sysmon ↔ memory:** Event ID 10 (0x1010 against lsass.exe) aligns with memory handles into SAM/SECURITY.
- **Process tree ↔ timeline:** python.exe (PID 6996) was active in the same window the image was captured.
- **Network ↔ memory:** SMTP egress at ~15:35 coincides with credentials resident in LSASS at capture time (12:35:24 UTC).



11. Threat Intelligence — APT28 Profile

11.1 Identity

Primary Name	APT28
Aliases	Fancy Bear, Sofacy, Sednit, STRONTIUM, OpsGroup Bluebravo
Attribution	Russian GRU (military intelligence)
Active Since	~2007
Motivation	Cyber-espionage, information operations
Typical Targets	Government, military, defense, diplomacy, elections, critical infrastructure

11.2 Notable Historical Operations

- **2015 — German Bundestag:** Large-scale data theft against the German parliament.
- **2015 — Ukraine power grid:** Disruptive attack contributing to widespread outages.
- **2016 — DNC breach:** Intrusion and data theft during the U.S. election cycle.
- **2018 — Olympic Destroyer:** Disruptive malware around the Winter Olympics.
- **2020+ — Election targeting:** Reconnaissance and credential operations against political entities.

11.3 TTP Overview

Phase	Representative Techniques
Initial Access	T1566 Spearphishing; watering-hole
Execution	T1204 User Execution; T1059 scripting
Privilege Escalation	T1134 Access Token Manipulation
Defense Evasion	T1027 Obfuscation; living-off-the-land
Credential Access	T1003 OS Credential Dumping
Exfiltration	T1041 Exfiltration Over C2 Channel

11.4 Lab-to-Adversary Correlation

Lab Behavior	Real APT28 Parallel
Spearphishing attachment (T1566.001)	Primary initial-access vector in major operations
Python payload (T1204.002)	Cross-platform tooling / scripting families
LSASS dumping (T1003.001)	Standard credential-access tradecraft
SMTP exfiltration (T1041)	Email/encrypted channels for data egress
Discovery cluster (T1087/T1016/T1057/T1033)	Routine pre-lateral-movement reconnaissance

11.5 References

- MITRE ATT&CK — Group G0007 (APT28).
- Public threat-intel reporting on BlueDelta / APT28 credential-theft campaigns.

Note: external URLs from the lab brief are retained in the analyst's working notes; summaries above are paraphrased for this report.

12. Indicators of Compromise (IoCs)

12.1 File Hashes

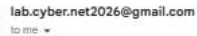
Artifact	Type	Value
memory.raw	Evidence	F9A7A6F9808F9394AEA4B298882427918B680681379FF342A771FAE894C0A22F
capture.pcapng	Evidence	052851E2E3F4575860FE4AD862EDE17453909B90575954C1189334821D4C4A11
python.exe	Process	CA60CF785B2314A6D6599ECED15BDF094E6DB171BEC996B97A70B995942C3C37
py.exe	Process	23D1894420C345219937EF7E43363029D92B78F180D29D56C88C94563378CB82
cmd.exe	Process	75320A519959CC6D089EA3EBA33C38CACCB7F138A025EA439BC9686CDB79DED4

12.2 Network Indicators

Type	Value	Context
Source IPv6	2a01:9700::12	Victim (public IPv6)
Destination IPv6	2a00:1450:4001:c21::6c	Gmail SMTP (exfil endpoint)
Source Port	64934	Ephemeral
Destination Port	587	SMTP submission + STARTTLS
SNI / Domain	smtp.gmail.com	TLS SNI observed in Client Hello
Protocol	TLS 1.3	Encrypted exfil channel
Frames	1474, 2996	Two connection attempts

12.3 Host Indicators

Type	Value
Domain	nulltack.com
Email	anmar@nulltack.com
Filename	WindowsSecurityUpdate.py / NulltackKatz_v1.2.py
Path	C:\NulltackLab\NulltackKatz_v1.2.py
Process behavior	python.exe (High integrity) spawning cmd.exe recon cluster
LSASS access mask	0x1010 (PROCESS_VM_READ PROCESS_QUERY_INFORMATION)



```
Credential Data:
{
  "NTLM_Hashes": [
    "Administrator:500:aad3b435b51404eeaad3b435b51404ee:31dbef0d16ae931b73c59d7e0c080cd...",
    "Lab.1000:aad3b435b51404eeaad3b435b51404ee:8848f7eae81b71af40d0bd830b7588c..."
  ],
  "Kerberos_Tickets": [
    "krbtgt ticket for domain: TESTLAB.LOCAL",
    "Domain ticket for LTTD (unknown local host)"
  ]
}
```

```

=====
PHASE 5] T1003.001 - OS Credential Dumping (LSASS Memory)
=====
+ ] Mimikatz found at: C:\Tools\mimikatz\x64\mimikatz.exe
  Commands: privilege::debug ; sekurlsa::logonpasswords ; exit
  [REAL] Dumping REAL credentials from LSASS memory

+ ] Executing REAL Mimikatz...
  Running: privilege::debug
  Running: sekurlsa::logonpasswords
  [X] Error executing Mimikatz: [WinError 225] Operation did not complete successfully because the file contains a virus or potentially unwanted software
=====
PHASE 6] T1041 - Exfiltration over C2 Channel (Gmail)
=====
+ ] Sending exfiltration email...

OK] Exfiltration successful!
  Report sent to: lab.cyber.net2026@gmail.com
  Subject: [APT28-BLUEDELTA-BLUEDELTA_20260620_213023] Compromised: Rabea - REAL Credentials Exfiltrated
  Local copy saved to: C:\NulltackLab\logs\exfiltration_report_BLUEDELTA_20260620_213023.txt
=====
PT28 SIMULATION COMPLETE
=====
+ ] Duration: 3.54 seconds
+ ] Campaign ID: BLUEDELTA_20260620_213023
+ ] Logs saved to: C:\NulltackLab\logs
=====
ITRE ATTACK TECHNIQUES DEMONSTRATED
=====
+-----+-----+
| Technique | Description |
+-----+-----+
| T1566.001 | Spearphishing Attachment - Email with payload |
| T1204.002 | Malicious File Execution - User runs tool |
| T1087.001 | Local Account Discovery - "net user" command |
| T1016 | Network Config Discovery - "ipconfig /all" |
| T1057 | Process Discovery - "tasklist" for AV/EDR |
| T1134 | Token Manipulation - SeDebugPrivilege |
| T1003.001 | LSASS Credential Dumping - REAL Mimikatz |
| T1041 | Exfiltration over C2 Channel - Gmail SMTP |
+-----+-----+

+ ] REAL Evidence files for SOC investigation:
  [FILE] C:\NulltackLab\logs\phishing_email_BLUEDELTA_20260620_213023.txt
  [FILE] C:\NulltackLab\logs\mimikatz_output_BLUEDELTA_20260620_213023_real.txt
  [FILE] C:\NulltackLab\logs\exfiltration_report_BLUEDELTA_20260620_213023.txt

EMAIL] Check your Gmail: lab.cyber.net2026@gmail.com
  Look for subject: [APT28-BLUEDELTA-...] REAL Credentials Exfiltrated

```

```

PS C:\NulltackLab> Get-FileHash C:\NulltackLab\evidence\memory.raw -Algorithm SHA256
>>

Algorithm      Hash
-----
SHA256         C18F50CF49E2C3C56913A8C711981638FD174F865F788447689C1D1BAAF3157B      C:\NulltackLab\evidence\memor...

PS C:\NulltackLab> Get-FileHash C:\NulltackLab\evidence\capture.pcapng -Algorithm SHA256

Algorithm      Hash
-----
SHA256         36DB0E99BF74AF1E3336F80CD856934FB793F76808B39AD0E80B3B77D411A2D1      C:\NulltackLab\evidence\captu...

PS C:\NulltackLab>

```

13. Detection Rules & Defensive Recommendations

13.1 Sysmon — LSASS Access

Target the credential-access stage by alerting on memory-read access to lsass.exe.

```
<ProcessAccess onmatch="include">
  <TargetImage condition="image">lsass.exe</TargetImage>
  <GrantedAccess condition="is">0x1010</GrantedAccess>
</ProcessAccess>
```

13.2 Network — SMTP Egress

Alert on SMTP submission to providers outside the approved corporate relay.

```
alert tcp $HOME_NET any -> !$MAIL_RELAY 587 ( \
  msg:"SMTP egress to non-approved server"; \
  flow:to_server,established; content:"STARTTLS"; \
  classtype:policy-violation; sid:2000002; rev:1; )
```

13.3 Behavioral — Interpreter Spawning Shells

- **Rule intent:** Alert when python.exe / py.exe spawns cmd.exe running net/ipconfig/tasklist within a short window.
- **Data source:** Sysmon Event ID 1 (process creation) with parent/child fields.
- **Tuning:** Baseline legitimate automation hosts to suppress known-good scripts.

13.4 Immediate Actions (0–30 days)

- Deploy/enforce email security gateway; block or sandbox executable and script attachments (.py, .exe, .js).
- Enable LSA protection (RunAsPPL) and Credential Guard where supported.
- Roll out Sysmon with the LSASS ProcessAccess rule above to all endpoints.
- Restrict outbound SMTP (587/465/25) to the approved mail relay only.

13.5 Short-Term (1–3 months)

- Deploy EDR with detections for LSASS access and interpreter-spawned shells.
- Implement network egress monitoring (Suricata/Zeek) with SNI logging.
- Segment finance and other sensitive functions; constrain east-west traffic.
- Stand up phishing-simulation and user-awareness training.

13.6 Long-Term (3–12 months)

- Advance toward a Zero-Trust architecture with strong identity controls.
- Integrate threat intelligence and run regular purple-team exercises.
- Mature detection engineering with continuous ATT&CK coverage assessment.

14. Conclusion & Attribution

14.1 Summary

The exercise successfully emulated an APT28-style credential-theft chain and produced detectable artifacts at every stage. Host telemetry, a full memory image, and a packet capture together provide a reproducible basis for the detections in Section 13.

14.2 Attribution Confidence

Attribution language here is scenario-based, not an assessment of a real intrusion. The emulated tradecraft is consistent with publicly documented APT28 behavior (spearphishing → execution → LSASS credential access → encrypted exfiltration). Confidence that the lab faithfully represents APT28 technique-level behavior is HIGH; this is an educational emulation rather than a live-actor attribution.

14.3 Scope Limitations

- Conducted in an isolated VM; results do not reflect production network conditions.
- Credential dumping ran in simulation mode; Event ID 10 values are the expected detection target.
- Exfiltration was an attempt for analysis purposes; no real secrets were transmitted.

Appendix A — Evidence Artifacts

Artifact	Location	SHA-256
Memory image	C:\NulltackLab\evidence\memory.raw	F9A7A6F9...894C0A22F
Packet capture	C:\NulltackLab\evidence\capture.pcapng	052851E2...21D4C4A11
Attack tool	C:\NulltackLab\NulltackKatz_v1.2.py	(see analyst notes)
Phishing email	C:\NulltackLab\logs\phishing_email_*.txt	(see analyst notes)

Appendix B — Forensic Tool Output (Excerpts)

B.1 Volatility 3 — windows.info

Kernel Base	0xf804e3600000
Build	26100
Architecture	64-bit
Processors	4
SystemTime	2026-06-11 12:35:24 UTC

B.2 Volatility 3 — lsass (pslist excerpt)

PID	PPID	ImageFileName	CreateTime (UTC)
892	724	lsass.exe	2026-06-11 12:29:58
724	652	wininit.exe	2026-06-11 12:29:57

Appendix C — Attack Timeline (Detail)

#	Time	MITRE	Action
1	15:30:00	T1566.001	Phishing email delivered
2	15:34:23	T1204.002	NulltackKatz_v1.2.py executed (High integrity)
3	15:34:50	T1087.001	net user
4	15:34:52	T1016	ipconfig /all
5	15:34:54	T1057	tasklist
6	15:34:56	T1033	net session
7	15:35:10	T1003.001	LSASS access (0x1010 expected)
8	15:35:30	T1041	SMTP exfiltration attempt (587)

— End of Report —